

tests/dynamic/analyzers/ auth_407_analyzer.sh — operator guide

Revision: 1 **Last modified:** 2026-07-01T00:00:00Z **Status:**
Active self-validated analyzer (§11.4.107(10)). Signal 6 of 6 for the
dynamic data plane — zero-trust per-user proxy auth. **Fresh
oracle** — no evidence.sh helper exists for this signal.

Companion (§11.4.18) to the in-source documentation block
at the top of the script.

Overview

Signal 6: **proxy auth enforced** (§11.4.69 permission_grant; design §11 ④ + §12 Squid per-user auth). **Both** halves are required: an UNAUTHENTICATED request through the proxy must be rejected with HTTP 407 (Proxy Authentication Required) **AND** a request with VALID credentials must succeed with 200. Either half alone is a half-truth; the §11.4.69-class bluff is a 200 WITHOUT credentials (auth not enforced — bypass).

Prerequisites

- Source library tests/dynamic/lib/analyzer_common.sh. (Uses ab_pass_with_evidence from evidence.sh when available, else ac_pass.)
- awk, tr, POSIX sh.
- Either a manifest (key=val):
 - unauth_http_code=407
 - auth_http_code=200
 - OR two captured %{http_code} files (unauth code, auth code).

Usage examples

```
# Manifest form:  
tests/dynamic/analyzers/auth_407_analyzer.sh analyze <manifest-  
file>
```

```
# Two-file %{http_code} form (unauth file, then auth file):
tests/dynamic/analyzers/auth_407_analyzer.sh analyze <unauth-code-
file> <auth-code-file>

# Self-validate (golden-good PASS + golden-bad FAIL) – the default
action:
tests/dynamic/analyzers/auth_407_analyzer.sh --selftest
```

Edge cases

- **Probe artefact / auth-code file missing** → FAIL.
- **Unauthenticated request returned 200** (auth bypassed) → FAIL: the 407-on-unauth half is what proves enforcement; asserting only that valid creds yield 200 would green an auth-disabled proxy where every request is 200 (§11.4.6 no-guessing).
- **Valid credentials rejected** (auth ≠ 200) → FAIL.

§11.4.115 RED_MODE polarity

Consuming suites run the §11.4.115 polarity citing this analyzer; RED reproduces an auth-bypass (unauth=200), GREEN guards the unauth→407 AND creds→200 contract.

Internal behaviour

- `#!/usr/bin/env bash`, POSIX-clean (`sh -n + bash -n`, §11.4.67).
- `_auth_get` parses `key=val` (strips whitespace); `_auth_first_token` reads the first token from a captured `%{http_code}` file (CR-stripped).
- Requires `unauth == 407` then `auth == 200`; on pass calls `ab_pass_with_evidence` (or `ac_pass` when `evidence.sh` is absent).
- Self-test asserts: manifest golden-good PASS; bypass (unauth=200) and creds-rejected → FAIL; two-file golden-good PASS; two-file unauth=200 → FAIL; missing-manifest negative → FAIL.

Related

- `tests/dynamic/lib/analyzer_common.sh` — sourced base.
- Fixtures: `tests/dynamic/analyzers/fixtures/auth_407/`.
- `config/squid/templates/auth.conf.tmpl` + `config/htpasswd` — the auth surface this signal validates.
- Constitution §11.4.69 / §11.4.107 / §11.4.115 / §11.4.6; design §11 ④ / §12.

Last verified

2026-07-01 — self-test PASS (manifest + two-file golden-good
PASS; bypass / creds-rejected / unauth=200 FAIL); sh -n + bash -n
parse-clean. Live auth probe is exercised in **P10**.